Which control?

Start from the requirement, not the product. Each panel gives the question to ask, the scenario words that decide it, and the wrong answer the question is built to tempt.

SC-500 Academy posters
Front: nineteen decisions SC-500 is built around
Checked against Microsoft Learn on 20 October 2026

Managed identity vs service principal

1.1.4 1.1.6

An application needs to call an Azure service. Which identity should it use?

- *"no credentials to store or rotate, app runs on an Azure VM / App Service"* → **Managed identity**
- *"GitHub Actions or an on-premises job must authenticate without a secret"* → **Workload identity federation, on an app registration or a user-assigned managed identity**
- *"one identity shared by several resources"* → **User-assigned managed identity**

Trap. Treating a managed identity as automatically least-privilege. It removes the credential problem, not the permission problem.

PIM vs Conditional Access

1.1.1 1.1.2

Is the requirement about how long someone holds privilege, or about the conditions of a sign-in?

- *"just-in-time, eligible, time-bound, approval to activate"* → **PIM**
- *"compliant device, location, sign-in risk, block legacy authentication"* → **Conditional Access**

Trap. Answering "require MFA for admins" with PIM alone, or "remove permanent admins" with Conditional Access.

Azure RBAC vs Azure Policy

1.3.1 1.3.5 1.3.7

Is the requirement about who can act, or about what any resource is allowed to look like?

- *"only the network team may manage virtual networks"* → **Azure RBAC**
- *"no storage account may allow public blob access, even for Owners"* → **Azure Policy (Deny)**
- *"add a tag automatically / deploy diagnostic settings when missing"* → **Azure Policy (Modify / DeployIfNotExists)**

Trap. Picking a custom role to stop people creating resources in the wrong region - that is a policy (allowed locations).

Preventive vs detective controls

1.3.1 1.3.3 4.1.1 4.1.3

Must the bad thing be stopped, or seen and acted on?

- *"must not be able to create"* → **Preventive (Azure Policy Deny)**
- *"notify the SOC when it happens"* → **Detective (alert / analytics rule)**

Trap. Answering a "prevent" requirement with Audit, or with a Defender alert.

Secrets vs keys vs certificates in Key Vault

1.2.5

What kind of sensitive material is it, and does the application ever need to see it?

- *"connection string, API key, password"* → **Secret**
- *"customer-managed key, encryption at rest, the key must never leave an HSM"* → **Key**
- *"TLS certificate with automatic renewal"* → **Certificate**

Trap. Storing an encryption key as a secret so the app can "use it" - the point of a key is that it never leaves the vault.

Key Vault: Azure RBAC vs access policies

1.2.3

How should data-plane access to a vault be granted?

- *"grant an app read access to one specific secret only"* → **Azure RBAC scoped to the secret**
- *"make vault access PIM-eligible and reviewable"* → **Azure RBAC**

Trap. Assuming Key Vault Contributor cannot read secrets - under access policies it can grant itself access.

Private endpoint vs service endpoint

2.1.2 2.3.6

Must the service have a private IP address in your network, or is it enough to limit its public endpoint to your subnets?

- *"private IP, reachable from on-premises, disable public access"* → **Private endpoint**
- *"allow only these subnets through the storage firewall, no extra cost"* → **Service endpoint**

Trap. Assuming a private endpoint closes public access - you must also disable public network access, and get DNS right.

NSG vs Azure Firewall vs security admin rule

2.3.1 2.3.2 2.3.8

Where should this traffic rule live - next to the workload, centrally for inspection, or as an organisation-wide floor?

- *"allow web tier to reach database tier on 1433 only"* → **NSG with application security groups**
- *"allow outbound only to *.contoso.com, block known malicious IPs"* → **Azure Firewall**
- *"block RDP from the internet in every virtual network, even if a team adds an allow"* → **Security admin rule**

Trap. Choosing an NSG to filter outbound traffic by domain name - NSGs cannot; Azure Firewall application rules can.

Restricted Content Discovery vs Restricted Access Control

3.1.1

Should overshared content stop appearing in Copilot and search, or should people lose access to it?

- *"stop it appearing in Copilot without disrupting the team"* → **RCD**
- *"only the legal group may open the site"* → **RAC**

Trap. Choosing RCD when the requirement is that unauthorised users must not be able to open the files.

On-behalf-of agent vs autonomous agent

3.1.4 3.1.6

Whose token does the agent use - a signed-in user's, or its own?

- *"assistant that acts for the signed-in user"* → **On-behalf-of - governed by user policies**
- *"nightly agent with no user present"* → **Autonomous - agent identity policies**

Trap. Assuming your All users MFA policy covers agents - it does not include agent identities or agents' user accounts.

AI gateway vs Foundry guardrails vs Defender for AI Services

3.1.7 3.1.8 3.1.9 3.1.10

Is the requirement about AI traffic, AI content, or detecting attacks?

- *"one app must not exhaust the token quota"* → **AI gateway (llm-token-limit)**
- *"scan what a tool returns before the agent uses it"* → **Foundry guardrail on tool response**
- *"SOC must be alerted to jailbreak attempts"* → **Defender for AI Services**

Trap. Expecting Defender for AI Services to block a prompt - it alerts. Blocking is guardrails, the gateway, or Defender real-time protection for agents (preview).

Web Application Firewall vs API Management

3.3.8 3.3.9

Is the requirement to block malicious requests, or to control which callers may use an API and how much?

- *"block SQL injection and XSS"* → **WAF managed rules (Prevention mode)**
- *"callers must present a valid Entra token, each limited independently"* → **API Management (validate-jwt, rate limits)**

Trap. Using a WAF to enforce per-consumer quotas or token validation - that is API Management.

Azure Bastion vs just-in-time VM access

3.2.2 3.2.3

Is the requirement to remove the public path to the VM, or to keep management ports closed until needed?

- *"RDP without a public IP, record sessions"* → **Azure Bastion (Premium for recording)**
- *"open port 3389 for one hour from one IP on request"* → **Just-in-time VM access**

Trap. Picking Bastion for "ports open only when needed", or JIT for "no public IP".

Agentless scanning vs the Defender for Endpoint agent

3.2.6 3.2.7 4.1.5

Do you need findings without installing anything, or real-time detection and response on the machine?

- *"vulnerability findings without installing anything"* → **Agentless scanning**
- *"detect and respond to attacker behaviour on the server"* → **Defender for Endpoint (EDR)**

Trap. Treating agentless scanning as a replacement for EDR.

Posture management vs workload protection

4.1.1 4.1.3

Is the requirement about how exposed things are, or about attacks happening now?

- *"prioritise findings, attack path, internet-exposed VM with a critical CVE"* → **Defender CSPM**
- *"alert on suspicious access to a storage account / SQL injection attempt"* → **Workload protection plan**

Trap. Expecting Defender CSPM to raise an alert for malware on a storage account - that is Defender for Storage.

Security Copilot roles vs underlying service roles

4.3.2 4.3.3

Does this role let someone use Security Copilot, or see the data Copilot reasons over?

- *"analyst can query Purview but not Sentinel through Copilot"* → **Missing Sentinel service role**
- *"restrict who can open Security Copilot"* → **Copilot contributor assignment**

Trap. Restricting Copilot contributor and believing that limits data exposure - data access was always the service roles.

Sentinel analytics tier vs data lake tier

4.2.7 4.2.9

Will this data drive detections and hunting, or is it kept for history and compliance?

- *"must be usable by analytics rules"* → **Analytics tier**
- *"keep seven years for compliance at low cost"* → **Data lake tier (total retention)**

Trap. Moving a table that feeds analytics rules to the data lake - the rules stop working.

Sentinel automation rule vs playbook

4.2.8

Is the requirement to route and manage incidents, or to take action in other systems?

- *"automatically assign and tag new incidents"* → **Automation rule**
- *"create a ServiceNow ticket / disable the user in Entra"* → **Playbook (run by an automation rule)**

Trap. Granting Playbook Operator to someone who must build playbooks - building needs Logic Apps permissions.

Windows Security Events via AMA vs Windows Forwarded Events

4.2.6

Should each server send its own Security log, or should endpoints forward to a collector?

- *"collect only these event IDs from each server"* → **Windows Security Events via AMA with custom XPath**
- *"endpoints must not connect to Azure directly"* → **Windows Forwarded Events via a collector**

Trap. Forwarding events with WEF and assuming the built-in SecurityEvent rules now cover them.

How to read a scenario

1. **Find the verb.** *Prevent, block, must not* wants a preventive control. *Detect, alert, notify* wants Defender or Sentinel. *Prove, report* wants compliance or audit.
2. **Find the subject.** A person, a workload, an agent, a network path or the data? That names the layer.
3. **Find the constraint that kills options.** *Without a credential. No public IP. No team can override. Without disrupting users. Without installing anything.*
4. **Find the scope.** *Every subscription, including future ones* means policy at a management group. *One secret only* means the narrowest role at the narrowest scope.
5. **Strike the answers that solve a different layer,** then the ones that detect when the question says prevent.

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

Which control?

The phrases that decide a question, and the answer they point to. Cover the right-hand side and test yourself.

SC-500 Academy posters
Back: scenario words and what they point to
Checked against Microsoft Learn on 20 October 2026

Domain 1 Identity, access, governance

"the same identity must survive a VM rebuild"	1.1.6
→ **User-assigned managed identity**	
"no credential in code or configuration, runs on Azure"	1.1.6
→ **Managed identity**	
"runs in GitHub Actions, no secret allowed"	1.1.4
→ **Workload identity federation: app registration or user-assigned MI**	
"three policies apply; one of them blocks"	1.1.2
→ **Blocked. Block beats every grant**	
"passkey or certificate; SMS must not count"	1.1.3
→ **Authentication strength, not plain MFA**	
"delegated vs application permission"	1.1.5
→ **Delegated = the user's reach. Application = tenant-wide, admin consent**	
"nobody holds the role until they need it; approval; four hours"	1.1.1
→ **PIM eligible assignment + role settings**	
"Contributor must not grant themselves secret access"	1.2.3
→ **Key Vault Azure RBAC permission model**	
"read one specific secret and nothing else"	1.2.3
→ **Key Vault Secrets User on that secret**	
"keys protected by HSMs; nobody may permanently delete"	1.2.2
→ **Premium SKU + purge protection**	
"app uses the URI with no version; old value restorable"	1.2.5
→ **New version, then disable the old one**	
"plaintext secrets on VM disks, AWS too, nothing installed"	1.2.6
→ **Agentless secret scanning (Defender CSPM or Servers Plan 2)**	
"no deployment failed, compliance still 40%"	1.3.1
→ **Deny only stops new requests: Modify or DeployIfNotExists + remediation**	
"ReadOnly lock broke an app that only reads blobs"	1.3.4
→ **Listing keys is a POST; ReadOnly blocks it**	
"which PCI DSS controls are we failing?"	1.3.2
→ **Regulatory compliance, after adding the standard**	
"stays visible, reason recorded, ends on its own"	1.3.3
→ **Exemption with an expiry date**	
"Owner at the management group, Reader at the subscription"	1.3.5
→ **Still Owner: assignments add up**	
"Resource Guard owned by the same administrator"	1.3.8
→ **Multi-user authorization stops mistakes, not a rogue admin**	
"must never be created, whatever tool deploys it"	1.3.9
→ **Azure Policy with Deny**	

Domain 2 Storage, databases, networking

"a SAS issued with no stored access policy must stop working"	2.1.4
→ **Rotate the key that signed it**	
"Shared Key disabled: what still works?"	2.1.1
→ **Entra ID and user delegation SAS**	
"attributable to a named user, never more than they have"	2.1.4
→ **User delegation SAS**	
"subnet allowed by the firewall, still 403"	2.1.2
→ **Network rules never grant; it needs a role or key**	
"monthly malware scan cap reached"	2.1.3
→ **Scanning stops for the month; uploads continue**	
"signed in with the SQL admin password, no MFA"	2.2.1
→ **Microsoft Entra-only authentication**	
"protected because Dynamic Data Masking is on"	2.2.1
→ **Not a boundary: WHERE clauses still reveal values**	
"auditing on at server and database level"	2.2.2
→ **Every event recorded twice**	
"SQL Server on a VM and Cosmos DB"	2.2.3
→ **One Defender for Databases plan; keep both types selected**	
"no application team can override it"	2.3.2
→ **Virtual Network Manager security admin rule (Deny)**	
"configuration saved, but has no effect"	2.3.2
→ **It was never deployed to the region**	
"NIC NSG denies at 150, subnet NSG allows"	2.3.1
→ **Blocked: inbound must pass both**	
"point-to-site users need Conditional Access"	2.3.4
→ **OpenVPN with Microsoft Entra ID authentication**	
"inspect spoke-to-spoke; internet leaves via on-premises"	2.3.3
→ **Private routing policy + 0.0.0.0/0 prefix, no internet policy**	
"legacy app, MFA and device compliance, no VPN"	2.3.5
→ **Entra Private Access app as an enterprise application**	
"a colleague at home still reaches the account"	2.3.6
→ **Disable public network access**	
"nslookup on-premises returns a public IP"	2.3.6
→ **Hybrid DNS for the private zone**	
"partner tenant, overlapping addresses, approve each connection"	2.3.7
→ **Private Link service**	
"broad network rule let HTTPS to any site through"	2.3.8
→ **Network rules run before application rules**	
"traffic is not reaching the firewall"	2.3.9
→ **Network Watcher next hop**	

Domain 3 Security for AI

"hide it from Copilot without disrupting the team"	3.1.1
→ **Restricted Content Discovery**	
"unauthorised users must lose access entirely"	3.1.1
→ **Restricted Access Control**	
"Microsoft 365 E5 and no Copilot licences"	3.1.1
→ **Data access governance activity reports only**	
"user can open the file; Copilot will not summarise it"	3.1.2
→ **Label grants VIEW but not EXTRACT**	
"protection works in one environment, not the new one"	3.1.3
→ **Threat detection is set up per environment**	
"autonomous agent; the All users policy never applies"	3.1.4
→ **Target agent identities in Conditional Access**	
"agent built by someone who has left; nobody accountable"	3.1.6
→ **Access package with expiry + sponsor lifecycle**	
"tenant-wide inventory of agents, and block some"	3.1.11
→ **Microsoft 365 admin center agent management**	
"one app's loop starves every other consumer"	3.1.7
→ **llm-token-limit keyed per subscription**	
"over-limit calls refused before the model"	3.1.7
→ **estimate-prompt-tokens="true" on llm-token-limit**	
"the agent has its own guardrail"	3.1.9
→ **It replaces the model's guardrail entirely**	
"show what the prompt said in the alert"	3.1.8
→ **Suspicious prompt evidence on the AI plan**	
"Defender CSPM on, Defender for AI Services off"	3.1.10
→ **AI posture and discovery, no runtime alerts**	

Domain 3 Servers, containers, apps

"server-side encryption is on; still flagged"	3.2.1
→ **Encryption at host: temp disks and caches**	
"every administrative session must be recorded"	3.2.2
→ **Azure Bastion Premium**	
"admins can still RDP straight from home"	3.2.2
→ **Remove public IPs and open ports**	
"Servers Plan 2 on, FIM reports nothing"	3.2.6
→ **File integrity monitoring must be turned on**	
"Azure VM, OS configuration audit"	3.2.9
→ **Machine Configuration extension + system-assigned identity**	
"on-premises server, same Policy and RBAC"	3.2.4
→ **Azure Arc**	
"a process that was not in the image"	3.3.1
→ **Binary drift detection**	
"ex-employee still reaches the cluster"	3.3.2
→ **Disable AKS local accounts**	
"whatever a developer submits, never privileged"	3.3.2
→ **Azure Policy for AKS, Deny at admission**	
"registry admin password in the pipeline"	3.3.3
→ **Disable the ACR admin account; use an identity**	
"key in a partner's integration URL"	3.3.5
→ **Function key: bearer secret, no identity**	
"workflow callback URL circulated"	3.3.6
→ **The URL holds a SAS: it is the credential**	
"the deployment console is still reachable"	3.3.7
→ **SCM site has its own access rules**	
"attack logged, app still exploited"	3.3.8
→ **WAF is in Detection mode**	
"gateway policies must be real, not advisory"	3.3.9
→ **Backend accepts only API Management**	

Domain 4 Posture and monitoring

"attack path analysis shows nothing"	4.1.1
→ **Plan enabled without Owner: agentless scanning never started**	
"secure score 82%, yet an obvious attack path"	4.1.1
→ **Scores grade findings; attack paths chain them**	
"only Defender for Servers Plan 1; add PCI DSS"	4.1.2
→ **Needs another plan to unlock standards**	
"subscriptions created next year"	4.1.3
→ **Policy at the management group**	
"AWS machines, Arc auto-provisioning declined"	4.1.4
→ **Agentless scanning still covers them; Arc unlocks the rest**	
"assets nobody remembers owning"	4.1.6
→ **Defender EASM**	
"analyst cannot close an incident"	4.2.2
→ **Microsoft Sentinel Responder**	
"40 solutions installed, nothing detects"	4.2.3
→ **Templates are not active rules**	
"duplicate incidents for Defender alerts"	4.2.4
→ **Turn off Microsoft incident creation rules**	
"firewall appliance logs"	4.2.5
→ **CEF via a Linux forwarder with AMA**	
"only these event IDs, nothing else"	4.2.6
→ **Custom XPath in the data collection rule**	
"forwarded events, SecurityEvent query is empty"	4.2.6
→ **They land in WindowsEvent**	
"no connector, keep 12 months, small subset detects"	4.2.7
→ **Custom table via Logs Ingestion API, split tiers**	
"playbook never runs, no error"	4.2.8
→ **Sentinel needs Automation Contributor on its resource group**	
"data from 14 months ago"	4.2.9
→ **Search job or KQL job on the data lake**	
"which emails did the attacker open?"	4.2.10
→ **MailItemsAccessed, Audit (Standard)**	
"what did they search for in the mailbox?"	4.2.10
→ **SearchQueryInitiated, Audit (Premium)**	
"Global Administrator cannot provision capacity"	4.3.1
→ **Needs Azure Owner or Contributor too**	
"Copilot answers Purview questions, not Sentinel"	4.3.2
→ **The user's own service roles decide**	
"bill tripled, analyst usage unchanged"	4.3.4
→ **Scheduled agents consuming SCUs**	
"runs daily as my admin account"	4.3.4
→ **Give the agent its own agent identity**	

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.